

Informe de auditoria — Total Secure App (DT360 Core)

Fecha: 2026-09-19 · **Version:** 2.1 (estado tras las correcciones) **Ruta:** /home/server-dt/Documentos/totalsecureapp

Historia de este documento. La **v1.0** (2026-09-15, por la mañana) fue la auditoria inicial: cuatro hallazgos criticos, ningun cambio aplicado. La **v2.0** (2026-09-15, por la tarde) registro que tres de los cuatro ya estaban cerrados, pero dejo varias secciones describiendo el sistema como estaba por la mañana. Esta **v2.1** corrige esas contradicciones e incorpora el trabajo del 16 y 17 de septiembre.

Resumen ejecutivo

Sistema de gestion operativa de guardias de seguridad: accesos, rondas, biometria, inventario y alertas, con aplicacion movil Android. **Es el sistema mas grande del servidor** (57 tablas, 880 usuarios, 4,5 GB en disco) y el **unico alcanzable desde internet**.

Esta bien construido: Laravel 13 modular, Sanctum y spatie/permission (las librerias correctas, no invenciones), PostgreSQL limitado a 127.0.0.1, secretos con fail-fast, y la **mejor documentacion del servidor** — incluido un LEEME-apk.txt que publica la huella del certificado y explica por que una version del APK no debe repartirse.

De los cuatro hallazgos criticos de la v1.0, tres estan cerrados y verificados. El que queda —la falta de HTTPS— no esta detenido por una dificultad tecnica: la configuracion con certbot ya esta escrita y probada en docker-compose.prod.yml . **Falta que se libere un dominio.**

Estado general

● **EN CORRECCION** — actualizado el 2026-09-19.

	Hallazgo	Estado
SEC-00	Toma de cuentas por procesar_paswchg	✓ CERRADO (2026-09-15) — y tambien la misma via en el portal web
CONT-01	Sin respaldo de base, secretos ni keystore	✓ HECHO (2026-09-15) — diario a las 03:00, probado restaurando
SEC-05	Fuga entre instituciones (T-30)	✓ CERRADO (2026-09-15) — era real: detalle de rondas y marcadores

	Hallazgo	Estado
SEC-01	Biometria sin cifrar por internet	● ABIERTO — espera que se libere el dominio
CONT-02	Keystore sin copia fuera del servidor	● PARCIAL — respaldado, pero en el mismo servidor

El riesgo que queda

Datos biometricos de 880 personas viajan por internet sin cifrar. Tres hechos verificados que se refuerzan: el sistema responde en `http://181.198.245.50:3031` (302), el backend se configura con esa URL sin TLS (`APP_URL` en `docker-compose.yml`), y la app movil **desactiva explícitamente** la proteccion de Android contra trafico en claro (`usesCleartextTraffic: true` en `app.json`).

Una contraseña filtrada se cambia. Una huella o un rostro, no.

Lo notable: la solucion **ya esta escrita en el proyecto**. `docker-compose.prod.yml` define nginx 1.27 con certbot y puertos 80/443, y `DESPLIEGUE-DOMINIO.md` documenta el procedimiento. Solo falta el dominio.

Y en segundo lugar, el keystore. El respaldo diario lo incluye y se verifico comparando su SHA-256, pero **la copia queda en este mismo servidor**. Perder la maquina es perder la identidad de la aplicacion: sin ese archivo no se puede publicar ninguna actualizacion mas, y no hay forma de revocarlo. El script ya tiene el paso de copia externa (`DESTINO_EXTERNO` , linea 76 de `backend/scripts/respaldo.sh`) y avisa en cada corrida mientras siga vacio; **falta decidir a que maquina copiar**.

Que se corrigio desde la version 1.0

El 15 de septiembre, los tres criticos cerrados (SEC-00, CONT-01, SEC-05), mas cinco bugs funcionales con su causa raiz localizada: el boton de panico que no avisaba a nadie, el QR que no salia en el PDF, las novedades de la web que se guardaban sin foto, la hora del preregistro imposible de escribir, y la disponibilidad para turnos extra sin control en el panel.

El 16 y 17 de septiembre, un repaso de infraestructura (cinco fallos: el 500 del panel, el limite de subida, la sesion que caducaba en una hora, los workers y los timeouts que se contradecian), la carga de **182 puestos y 558 turnos**, y el **APK 1.0.7** (versionCode 8), firmado con el keystore de produccion y verificado dentro del bundle.

541 tests en verde en la ultima corrida registrada (2026-09-17).

Arquitectura

Laravel 13 modular (Acceso, Administracion, MobileApp, PortalApi) + PHP 8.3 + PostgreSQL 16 + nginx, mas app React Native/Expo (SDK 57). Contenedor MariaDB suelto con la base heredada V1.

Codigo

No se evaluo linea por linea. Las decisiones de dependencias son correctas: Sanctum para tokens, spatie/laravel-permission para roles, dompdf para PDF. La modularizacion permite que la API movil evolucione sin arrastrar al portal.

Docker

Correcto en lo esencial: base solo local, fail-fast en `DB_PASSWORD`, healthcheck con `service_healthy`. Debilidad: bind mounts del codigo fuente en produccion.

Hallazgo positivo verificado: el comentario del compose documenta un incidente previo — `APP_DEBUG=true` en produccion filtrando la contraseña de la base por las trazas de Ignition— y **hoy esta corregido:** `APP_ENV=production`, `APP_DEBUG=false`.

Base de datos

PostgreSQL 16, 57 tablas, correctamente limitada a `127.0.0.1`. 880 usuarios, 12.664 biometrias, 9.769 accesos, 8.667 rondas. **Las 57 tablas no estan documentadas una por una:** es el trabajo pendiente mas grande.

Seguridad

1 critico abierto (SEC-01, la exposicion sin cifrar), 2 altos y 3 medios. El otro critico de seguridad —la toma de cuentas— se cerro el 15 de septiembre por las dos vias, la API y el portal web.

Lo que **si** esta bien resuelto: el login (`Hash::check`, estado, gestion y rol antes de emitir el token), el webhook de WhatsApp (`hash_equals` y 404 sin token configurado — la mejor implementacion del servidor), y que solo 4 de 55 rutas sean publicas.

Documentacion

La mas completa del servidor. Trece documentos previos, seis fases de historia de construccion, especificacion OpenAPI, guias de despliegue y migracion. `LEEME-apk.txt` es un ejemplo de documentacion operativa util: explica no solo que instalar sino **que NO instalar y por que**.

Backup

✓ **Diario y probado**, desde el 2026-09-15. `backend/scripts/respaldo.sh` corre a las 03:00 por el crontab del dueño del repositorio y cubre los cuatro elementos irrecuperables: la base PostgreSQL (formato custom, para poder restaurar una sola tabla), la MariaDB de la V1, los secretos con `APP_KEY` y el **keystore de firma**. Paquete diario de ~7 MB, 14 días de retención; las fotos van aparte por `rsync` incremental. Verificado restaurando el índice del dump y comparando el SHA-256 del keystore. Procedimiento en `backend/scripts/RESPALDO.md`.

● **La salvedad:** todo queda en este mismo servidor. Ver CONT-02.

Operacion

Unico sistema expuesto a internet. Sin monitoreo. **Healthcheck en la base (`pg_isready`) y en el backend (`docker/php/healthcheck.php` , desde el 2026-09-17); **nginx sigue sin uno.****

Mobile

● **Documentado completo.** App `com.dt360.coreapp` **1.0.7 (versionCode 8)**, React Native/Expo SDK 57, cinco permisos sensibles, firmada con el keystore de produccion y con la huella del certificado publicada.

Dato operativo relevante: hasta la version 1.0.2 **el boton de EMERGENCIA no existia** en la aplicacion de los guardias, y **la 1.0.2 tampoco puede recuperar contraseñas** (manda el contrato viejo, anterior al cierre de SEC-00). Hay que censar que version tiene cada tablet y actualizarlas a la 1.0.7.

Riesgos

Riesgo	Probabilidad	Impacto	Exposicion
Toma de cualquier cuenta	—	—	✓ cerrada el 2026-09-15, por las dos vias
Interceptacion de biometria y credenciales	media-alta	muy alto	muy alta — internet, sin TLS
Perdida del keystore	media	muy alto	alta — la unica copia esta en este servidor
Perdida total de datos	baja	muy alto	media — hay respaldo diario, pero en el mismo servidor
Tablets sin boton de panico o sin recuperacion de clave	media	alto	media — si alguna sigue por debajo de 1.0.7
Fuga entre instituciones	—	—	✓ verificada y cerrada el 2026-09-15
<code>v1_analisis</code> fuera de control	media	medio	media

Inconsistencias

INC-01 — Despliegue con HTTPS preparado y sin activar ●

Configuracion prevista: `docker-compose.prod.yml` con nginx 1.27, certbot y puertos 80/443; `DESPLIEGUE-DOMINIO.md` documenta el procedimiento. **Realidad:** corre `docker-compose.yml` con `nginx:alpine` en el 3031, sin TLS. **Impacto: critico.** La solucion al mayor riesgo del sistema existe y no se uso. **Bloqueado por la falta de dominio, no por trabajo tecnico.**

INC-02 — Contenedor `v1_analisis` fuera de todo compose

MariaDB 10.4 creado el 2026-09-07, sin proyecto compose. No se recrea y no aparece en los archivos del proyecto. **Ya entra en el respaldo diario** desde el 2026-09-15, que lo trata como caso aparte justamente por esto. **Impacto:** medio.

INC-03 — `openapi.yaml` posiblemente desactualizado

Del 2026-09-07; el APK vigente es del 17. No se contrasto contra las rutas reales. **Recomendacion:** usar `php artisan route:list` como referencia.

INC-04 — Las variables del compose pisan al `.env`

Documentado por el propio proyecto. Se registra porque **es una trampa que cuesta horas:** cambiar el `.env` no surte efecto.

INC-05 — `repomix-output.xml` en el proyecto

1,2 MB de volcado de codigo, del 2026-09-08. No es documentacion, se desactualiza solo, y **pertenece a root** en un repositorio que debe ser todo del usuario que opera el servidor.

Documentacion faltante

- **Manual de usuario y manual de administrador:** requieren credenciales de prueba y una sesion dedicada. No se generaron para no inventar funcionalidades ni navegar produccion.
- **Las 57 tablas,** una por una.

Recomendaciones

ID	Hallazgo	Categoria	Severidad	Estado y recomendacion
SEC-01	Biometria y credenciales por internet sin cifrar	Seguridad	● CRITICO	ABIERTO. Activar HTTPS en cuanto haya dominio; ya esta preparado en <code>docker-compose.prod.yml</code> . Luego quitar <code>usesCleartextTraffic</code> y recompilar el APK

ID	Hallazgo	Categoria	Severidad	Estado y recomendacion
CONT-02	Keystore sin copia fuera del servidor	Continuidad	● CRITICO	ABIERTO. El script ya tiene el paso (<code>DESTINO_EXTERNO</code>); falta decidir el destino. Sin el keystore, no hay mas actualizaciones de la app
SEC-02	Bind mounts de codigo en produccion	Seguridad	● ALTO	Abierto. Imagen con <code>COPY</code> para produccion
MOV-01	Tablets sin censar	Operacion	● MEDIO	Abierto. Censar versiones y actualizar a 1.0.7 : por debajo de 1.0.2 no hay boton de panico, y la 1.0.2 no recupera contraseñas
INC-02	<code>v1_analisis</code> fuera de todo compose	Operacion	● MEDIO	Abierto. Definir si la migracion concluyo y apagarlo. Ya se respalda
OPS-01	Healthchecks	Operacion	● MEDIO	PARCIAL. Base y backend ya tienen; falta nginx
DOC-01	57 tablas sin documentar	Documentacion	● MEDIO	Abierto. Sesion dedicada
INC-03	<code>openapi.yaml</code> a verificar	Documentacion	● BAJO	Abierto. Contrastar con <code>route:list</code>
SEC-00	✓ RESUELTO — <code>procesar_paswchg</code> publico y sin validar token	Seguridad	● CRITICO	Hecho: codigo con <code>random_bytes</code> , guardado hashado, con caducidad, de un solo uso y comparado con <code>hash_equals</code> ; ya no vuelve en la respuesta. El portal web tenia el mismo agujero y tambien se cerro
CONT-01	✓ RESUELTO — Sin respaldo de base, secretos ni keystore	Continuidad	● CRITICO	Hecho: <code>scripts/respaldo.sh</code> diario a las 03:00, con los cuatro elementos. Verificado restaurando el indice del dump y comparando el SHA-256 del keystore
SEC-05	✓ RESUELTO — Aislamiento entre instituciones sin verificar	Seguridad	● MEDIO	Se verifico y habia fuga : el detalle de rondas y los marcadores de local filtraban solo por el parametro de la URL. Un Supervisor leia rondas de otro cliente y editaba las coordenadas de sus QR . Cerrado, con 12 tests
GES-01	✓ RESUELTO — Repositorio sin remoto	Gestion	● MEDIO	Publicado en GitHub (<code>megaman0012/appguardia</code>). El keystore no se publica: <code>.gitignore</code> excluye <code>/apk/</code> y <code>*.jks</code> , y su custodia aparte sigue pendiente (CONT-02)

Prioridad recomendada

1. **SEC-01 — activar HTTPS.** Es el unico critico de seguridad que queda y el trabajo tecnico ya esta hecho. **Depende de que se libere el dominio**, asi que lo accionable hoy es pedirlo.

2. **CONT-02 — copiar el respaldo y el keystore fuera del servidor.** Toma minutos una vez decidida la maquina de destino, y su perdida es irreversible.
 3. **MOV-01 — censo de tablets** y actualizacion a 1.0.7. Una app de guardias sin boton de panico es un riesgo operativo directo.
 4. **OPS-01 — healthcheck de nginx**, que es lo unico que falta de ese punto.
 5. **SEC-02, INC-02, DOC-01, INC-03** y el resto.
-

Version 1.0: ningun cambio fue aplicado durante la auditoria. A partir de la v2.0 este documento registra las correcciones ya desplegadas; el detalle de cada una, con su causa raiz, esta en `ROADMAP.md`.